

CASE 2

ZAMAN ÇİZELGESİ

Saat	Kaynak	Olay	Varlık	Durum
09:12:04	mail	SMTP bağlantısı unknown[45.137.21.88] üzerinden kuruldu	mail gateway	OBSERVED
09:12:05	mail	Fatura_2026_4471.docm eki geldi — from=billing@acme-invoices.com, spf=fail, dkim=none, disposition=delivered	b.kaya	OBSERVED
08:29:50	winsecurity 4624	b.kaya normal logon (LogonType=2, IP=127.0.0.1) — güne tek giriş	FIN-WS03	OBSERVED
09:41:12	sysmon	WINWORD.EXE, Fatura_2026_4471.docm dosyasını açtı	FIN-WS03 / b.kaya	OBSERVED
09:41:15	dns	static-cdn-analytics.com ilk kez 45.137.21.88'e çözümlendi (beacon başlangıcı)	FIN-WS03	OBSERVED
09:41:18	sysmon	mshta.exe tetiklendi, static-cdn-analytics.com/u.hta çağrıldı	FIN-WS03	OBSERVED
09:41:19	sysmon	powershell.exe encoded komutla başlatıldı (mshta'nın child'ı)	FIN-WS03	OBSERVED
09:41:24	sysmon	powershell.exe, 45.137.21.88:443 (static-cdn-analytics.com) bağlantısı açtı	FIN-WS03	OBSERVED
09:41:31	sysmon	svchost_update.exe başlatıldı (powershell'in child'ı)	FIN-WS03	OBSERVED
09:41–10:09	firewall	45.137.21.88'e 32 düzenli bağlantı	FIN-WS03	OBSERVED
09:41:15–10:09:35	dns	38 A-record beacon (60-63sn aralık) + 4 TXT/NXDOMAIN tünelleme sorgusu (09:51:20, 09:56:25, 10:01:28, 10:05:30) — beacon burada tamamen duruyor	FIN-WS03	OBSERVED
10:05:47	sysmon	m.exe başlatıldı (svchost_update.exe'nin child'ı)	FIN-WS03	OBSERVED
10:05:48	sysmon	m.exe, lsass.exe'ye erişti (GrantedAccess=0x1410) — credential dumping girişimi	FIN-WS03	OBSERVED (girişim) / INFERRED (başarı)
10:31:44	auth	svc-backup hesabıyla parola ile SSH girişi, kaynak FIN-WS03 (192.168.20.45)	app-db01	OBSERVED
10:33:02	auth	sudo: svc-backup → root, tar -czf /tmp/db_dump.tgz /var/lib/mysql/customers	app-db01	OBSERVED
10:36:20	auth	svc-backup oturumu kapandı	app-db01	OBSERVED
10:38:02	winsecurity 4698	SystemTelemetrySync scheduled task oluşturuldu (SubjectUserName=b.kaya) — persistence, static-cdn-analytics.com/b.exe indirip svchost_update.exe adıyla çalıştırıyor. Ek logon yok (08:29 ile aynı oturum); tetikleyen process sysmon'da görünmüyor.	FIN-WS03	OBSERVED (oluşturma) / INFERRED (kaynak process)

11:20:37	firewall	480 MB (503.316.480 byte) transfer, hedef 185.220.101.44 — sysmon'da hiç görünürlük yok (process/PID/port bilgisi yok), DNS beacon'ın kapanmasından 71 dk sonra	FIN-WS03	OBSERVED (transfer) / INFERRED (db_dump.tgz bağlantısı)
----------	----------	---	----------	---

IOC LİSTESİ

Tip	Değer	Değerlendirme	Kanıt
Domain	static-cdn-analytics.com	Confirmed malicious (C2 + persistence kaynağı)	dns, sysmon, winsecurity
IP	45.137.21.88	Confirmed malicious (C2/beaconing hedefi)	firewall, dns, sysmon, mail
IP	185.220.101.44	Suspicious (muhtemel exfiltration hedefi) — görünürlük boşluğu nedeniyle process/bağlam bilgisi yok	firewall
Dosya	Fatura_2026_4471.docmSHA256: dd50d653c274434bcd62fbde66b49e144ac0658f844ea0528b3cc035dc3a2540	Confirmed malicious (initial delivery)	sysmon, mail
E-posta adresi	billing@acme-invoices.com	Confirmed malicious (spoofed sender — spf=fail, dkim=none)	mail
URL	http://static-cdn-analytics.com/u.hta	Confirmed malicious	sysmon
URL	http://static-cdn-analytics.com/b.exe	Confirmed malicious (persistence payload)	winsecurity (decoded task content)
Dosya adı	svchost_update.exe (Temp altında)SHA256: 746f10f315b4beb6823d1b47539e6c44079434d00e0efa4baa2b30be6b1f3d2b	Confirmed malicious (masquerading)	sysmon
Dosya adı	m.exe (Temp altında)SHA256: 97ef7e9ffbcecb476ee47b94fe86b5fc57b30a41f6933cffe3dc8b4ae6f2854e	Confirmed malicious (credential dumping aracı)	sysmon
Scheduled Task	SystemTelemetrySync	Confirmed malicious (persistence)	winsecurity
Hesap	b.kaya	Kullanılan hesap (FIN-WS03) — kasıtsız kullanım OBSERVED seviyesinde doğrulandı (ek logon yok)	sysmon, winsecurity, mail, 4624
Hesap	svc-backup	Kullanılan hesap (app-db01) — meşru mü kötüye mi kullanılmış netleşiyor	auth
Host	FIN-WS03 (192.168.20.45)	Ele geçirilmiş host	tüm kaynaklar
Dosya	/tmp/db_dump.tgz (app-db01)	Muhtemel exfiltration hazırlığı — bağlantısı henüz kesinleşmedi	auth

MITRE ATT&CK EŞLEŞMESİ

Teknik Adı	ID	Gözlemlenen Davranış	Confidence
Phishing: Spearphishing Attachment	T1566.001	Fatura_2026_4471.docm eki, spoofed sender (spf=fail, dkim=none)	Yüksek
User Execution: Malicious File	T1204.002	Kullanıcının .docm dosyasını açması	Orta
System Binary Proxy Execution: Mshta	T1218.005	mshta.exe ile uzaktan .hta çalıştırma	Yüksek
Command and Scripting Interpreter: PowerShell	T1059.001	Encoded powershell komutu	Yüksek
Application Layer Protocol: Web Protocols	T1071.001	powershell.exe'nin HTTPS (443) üzerinden C2	Yüksek
Application Layer Protocol: DNS	T1071.004	38 A-record beacon + 4x TXT/NXDOMAIN sorgusu, düzenli aralık	Yüksek
Masquerading	T1036.005	svchost_update.exe, meşru Windows dosya adını taklit ediyor	Yüksek
Scheduled Task/Job: Scheduled Task	T1053.005	SystemTelemetrySync görevi	Yüksek
OS Credential Dumping: LSASS Memory	T1003.001	m.exe → lsass.exe erişimi, GrantedAccess=0x1410	Yüksek (girişim), başarı doğrulanmadı
Valid Accounts	T1078	svc-backup hesabıyla FIN-WS03'ten app-db01'e giriş	Orta
Remote Services: SSH	T1021.004	svc-backup, FIN-WS03'ten SSH ile app-db01'e bağlandı	Orta
Archive Collected Data	T1560	tar -czf db_dump.tgz	Orta
Exfiltration Over C2 Channel	T1041	480 MB transfer, 185.220.101.44 — DNS/HTTPS C2 kanalı 10:09'da kapanmış, transfer 71 dk sonra	Düşük
Exfiltration Over Alternative Protocol	T1048	480 MB → 185.220.101.44, C2 IP'sinden farklı hedef, ayrı ve görünürlüğü olmayan bağlantı	Düşük — sysmon görünürlük boşluğu nedeniyle T1041/T1048 arasında kesin karar verilemiyor

Görünürlük Boşlukları

1. Scheduled task'ın kaynak process'i

SystemTelemetrySync task'ının (10:38:02) hangi process tarafından oluşturulduğu Sysmon EventID=1 verisinde gözlemlenemiyor. 10:05:47 (m.exe) ile 10:40:12 (notepad.exe) arasında hiçbir

process creation kaydı yok — task oluşturma anını (10:38:02) kapsayan pencerede boşluk var. 4624 (logon) sorgusu, task'ın ayrı bir saldırgan oturumu değil, mevcut (08:29'da açılan) oturum içinde oluştuğunu OBSERVED seviyesinde doğruluyor; ama task'ı tam olarak hangi process'in çağırdığı INFERRED kalıyor.

Hangi kaynak çözerdi:

Sysmon config/filtreleme ayarlarının doğrulanması; PowerShell Script Block Logging (Event ID 4104) etkinleştirilmesi.

2. Network connection logging kapsamı (185.220.101.44)

Sysmon EventID=3 verisi, FIN-WS03 için tüm zaman aralığında sadece 1 kayıt içeriyor (09:41:24, powershell.exe → 45.137.21.88:443). 45.137.21.88'e giden diğer 31 bağlantı ve 185.220.101.44'e giden 480 MB'lık transfer, hiçbirinde process/PID/port bilgisi yok. Bu, belirli bir olayın eksikliği değil, host genelinde network connection telemetrisinin yetersiz olduğuna işaret ediyor. Transferin db_dump.tgz ile bağlantısı bu nedenle INFERRED kalmak zorunda.

Hangi kaynak çözerdi:

Sysmon EventID=3 filtreleme kurallarının incelenmesi; proxy/NGFW content-aware loglama veya EDR network telemetrisinin çapraz kontrolü.

Açık Notlar

- b.exe için hash yok — dosyanın indirilme/çalıştırılma anı sysmon'da doğrulanamadı; adı yalnızca winsecurity 4698 task içeriğinden (decoded) biliniyor.
- Mail gateway, spf=fail / dkim=none olan bir maili yine de teslim etti (disposition=delivered) — bu bir kontrol zafiyeti; öneriler kısmına taşınmalı.